Case Study: 2

* Securing the University Examination System

A ~~universti~~ university uses an Operating System based examination management system to store student records, examination marks, faculty details, & question papers. The system has 3 main user groups: Students, Faculty and Administrators. Students should be able to view only their own marks and download permitted learning materials. Faculty members need to view student records and enter or modify marks. Administors manage user accounts, permissions, and system configuration.

The university has assigned permissions through roles, but an audit review identifies the following events:

- At 10:00, the account Student07 has 3 failed login attempts.
- At 10:03, Student07 successfully logs in.
- At 10:04, Student07 attempts to open GramMarks.xlsx, which contains marks for an entire class.
- At 10:05, the system records an attempted modification of GramMarks.xlsx by Student07.
- At 10:15, Faculty02 modifies marks in GramMarks.xlsx and saves the file successfully.
- At 10:20, an administrator discovers that a former faculty member's account is still active.

- The audit log is stored on the same server, and users with broad permissions may be able to modify or delete it.

The University wants to protect confidentiality, integrity, and availability; prevent unauthorized access; maintain accountability; and investigate suspicious activity. You are asked to recommend appropriate OS access control, security administration, and auditing measures.

Questions (with solutions)

Q1. Identify the main security problems in the case study. List at least 4 risks or weaknesses indicated by the scenario.

Ans: i. Student07 makes 3 failed login attempts, which may indicate a password related problem or a possible unauthorized login attempt.

ii. Student07 successfully logs in and then attempts to access ExamMarks.xlsx, which contains marks for all students.

iii. Student07 attempts to modify marks file, even though students should not have permission to change marks.

iv. A former faculty members account is still active.

Q2. Explain the difference between authentication and authorization using Student07 as an example.

Ans: Authentication means verifying the identity of a user. In this case, the system records 3 failed login attempts by Student07 at 10:00, followed by a successful login at 10:03.

Authorization means checking what actions a user is permitted to perform. Student07 may access permitted learning materials and their own marks, but should not be allowed to modify ExamMarks.xlsx.

Q3. Recommend an access control policy for Students, Faculty and Administrators.

Ans: The university should used Role Based Access Control (RBAC), in which permissions are assigned according to the user's role.

- Students: Can view their own marks and download permitted learning materials.
- Faculty: Can view student records and enter or modify marks for their assigned subjects.
- Administrator: Can manage user accounts, permissions and system ~~of~~ configuration.

RBAC is suitable because it makes access management easier and prevents users from accessing information or performing actions beyond their responsibilities.

Q4. Prepare a suitable Access Control list (ACL) for ExamMarks.xlsx.

Ans:
- Student → Denied → Student should not view class wise marks file or tamper with grade.
- Faculty → Allowed → faculty need to review records and Enter Marks. Delete rights to prevents to avoid accidental loss.
- Administrator → Allowed → Administer manage system storage but should not alter academic marks directly to prevent corruption of data integrity.

Q5. Explain how principle of least privilege should be applied.

Ans: The Principle of least Privilege means giving users only the permission they used to perform their work.

- Students: should only view their own marks and permitted learning materials. write and delete permissions for the marks file must be removed.

- Faculty: Should view and modify marks for their assigned subjects but should not delete the entire marks file.

- Administrator: Should manage accounts, permissions, and system settings without automatically recieving unnecessary file-editing or deletion permissions.

This principle reduces accidental changes, misuse of accounts, and unauthorized access to confidential information.

Q6. Interpret the audit events from 10:00 to 10:05. What should the security team do next?

Ans: The sequence of events is suspicious because Student07 makes three failed login attempts at 10:00, successfully logs in at 10:03, attempts to open the file at 10:04, and attempts to modify the file at 10:05.

The security team should:

- Review the login records and verify weather the successful login was legitimate.
- Check weather Student07 was authorized to access the marks file.
- Investigate weather any marks were actually changed.
- Preserve the audit logs and check for other suspicious acts.

The faculty member's successful marks update at 10:15 should also be checked against their assigned permissions. The former faculty member's active accounts should be investigated seperately.

Or. Identify any 5 events that should be recorded in the audit logs.

Ans:
- Successful & failed login attempts
- Attempts to open or access files.
- Changes to student marks
- Creation, deletion or modification of user accounts.
- Changes to roles and access permissions.

These records help the university identify suspicious activities and investigate security incidents.

Or. Explain why audit logs must be protected & recommend two ways to protect them.

Ans: Audit logs must be protected because they provide evidence of user activities and security incidents. If someone modify or deletes the logs, the university may loose important evidence during an investigation.

→ ways to protect them are:-

i: Restrict access: Only authorized security personnel should be able to manage the logs.

ii: Use Temper - Resistant Storage: Store logs on a seperate, protected server and use mechanisms that detect unauthorized changes.

Q9. What action should be taken regarding the former faculty member's active account?

Ans: The university should immediately disable the former faculty member's account and revoke their access to the university system. It should also terminate active sessions, review the account's previous activities and remove any unnecessary permissions.
This is important because former members no longer require access the university resources. Disabling inactive accounts reduces the risk of unauthorized access and data misuse.

Q10. Suggest a practical incident response and corrective action plan for the university.

Ans: Investigate: Review the audit logs, verify students activities & check whether any marks were changed without authorization.

- Review Access: Disable the former faculty member's account and examine the permissions of Students, faculty & Administrators.
- Improve Security: Apply RBAC and the principle of least privilege, enforce strong passwords and multi-factor authentication wherever possible.
- Monitor Regularly: Protect audit logs, review suspicious activities, conduct periodic access reviews and verify that corrective measures are effective.